

Gerçek Phishing E-postası Analizi

Sample-10 – "Microsoft Account Unusual Sign-in"

Başlık zinciri:

En alttaki (4.) satır saldırganın gönderen sunucusu, thculturfdes.co[.]uk (89.144.44[.]2), bu satırı saldırgan yazmış olabilir. Ama üstündeki 3 satır Microsoft'un kendi altyapısı (outlook.com, protection.outlook.com), yani mail gerçekten Microsoft'un mail sistemine girmiş, onlar sadece taşımışlar, içeriği doğrulamamışlar.

Zarf vs From:

From access-accsecurity[.]com diyor, Return-Path thculturfdes.co[.]uk diyor, ikisi tamamen farklı. Bu, Microsoft'tan geliyormuş gibi görünen ama SMTP seviyesinde başka bir alan adından gönderilen klasik bir sahtecilik.

Kimlik doğrulama:

spf=none, dkim=none, dmarc=permerror

Hiçbir doğrulama geçmemiş, en net durum bu.

Görünen ad:

"Microsoft account team" yazıyor ama gerçek adres no-reply@access-accsecurity[.]com
Microsoft'un gerçek bir domaini değil.

Gövde/bağlantılar:

Mailde tıklanabilir bir web linki yok, üç buton da aslında "mailto:" linki, hepsi saldırganın Gmail adresine (sotrecognizd@gmail[.]com) gidiyor. Hedef bir sahte giriş sayfası değil, kullanıcıyı doğrudan saldırganla mail yazışmasına çekmek, muhtemelen "hesabını doğrulamak için bize yaz" diyerek sosyal mühendislikle kimlik bilgisi toplama.

Sample-95 – "Trustwallet – Unverified Accounts Suspended"

Başlık zinciri:

En alttaki gerçek gönderen a227-147.mailgun[.]net

Mailgun, meşru bir toplu mail gönderim servisi, saldırganlar bunu kötüye kullanmış.

Zarf vs From:

From emails.gorgias[.]com, Return-Path gorgias[.]io

Gorgias da gerçek bir müşteri destek platformu, saldırgan bu platformu (ya da çalınmış/kötüye kullanılan bir hesabını) kullanarak mail göndermiş.

Kimlik doğrulama:

spf=pass, dkim=pass, ama dmarc=fail. SPF ve DKIM geçmiş diye "meşru" denemez, çünkü ikisi de gerçekten Gorgias'ın altyapısını doğruluyor. Sorun DKIM imzasını atan domain (gorgias.io) ile kullanıcının gördüğü From domaininin (emails.gorgias.com) hizalı olmaması, DMARC tam bunu yakalıyor.

Görünen ad:

Trustwallet-Support yazıyor ama adres gerçek Trustwallet'a ait değil, üçüncü parti bir mail platformuna ait.

Gövde/bağlantılar:

"Confirm my wallet" linki önce meşru bir yönlendirme servisinden (usertest.sciquest[.]com) geçiyor, sonunda gerçek hedefe varıyor: drop-coin-availablenow.site44[.]com

İsim bile "coin drop" temalı, tipik kripto oltalama sayfası.

Sample-800 – "#rodrigofp: Claim 500 BNB Now"

Başlık zinciri ve Zarf vs From:

İkisi de AYNI: yx2nqoz.onmicrosoft[.]com

İlk bakışta güven verici görünüyor ama saldırgan Microsoft 365'te ücretsiz/geçici bir kiracı (tenant) açıp gerçek Microsoft altyapısından mail gönderiyor. Bu yüzden SPF de geçiyor, compauth=pass bile diyor. Kaynağın kendisi meşru bir servis ama hesap saldırılarına ait.

Kimlik doğrulama:

spf=pass, dkim=none, dmarc=bestguesspass (gerçek bir DMARC kaydı yok, sistem tahmin ediyor).

Üç doğrulamadan hiçbirisi gerçek bir güvence vermiyor, sadece meşru altyapıdan geldiği için "pass" görünüyor.

Gövde:

Gövde metni tuhaf, aynı alakasız cümle bloğu ("Hey {name}, can we hop on a quick call...") defalarca tekrarlanmış. Bu, Mandiant okumasında görülen "İncil ayetleriyle doldurma" tekniğinin bir benzeri. İstatistiksel spam filtrelerini şaşırtmak için anlamsız/tekrar eden dolgu metni.

Bağlantı:

Link metni "Join Ai" yazıyor ama buradaki "o" normal Latin "o" değil, Yunanca omicron karakteri, göz ile ayırt edilemeyen bir homoglyph hilesi. Gerçek hedef önce meşru bir mail izleme servisinden (click.pstmrk[.]it – Postmark) geçiyor, sonunda appbnb.web[.]app'e varıyor (Google Firebase üzerinde barındırılan sahte bir BNB/Binance sayfası).

Üç Örnek Üzerine Çıkarılanlar

Üçü de aynı temel dersi farklı şekilde veriyor: spf/dkim/dmarc "pass" görmek asla tek başına yeterli değil, çünkü saldırganlar ya çalınmış/kötüye kullanılan meşru altyapı (Mailgun, Gorgias, Microsoft 365 tenant) kullanıyor ya da bu doğrulamaları hiç geçmiyor. Karar her zaman Return-Path ile From'un yan yana konmasıyla, ve bağlantının gerçek nihai hedefinin takip edilmesiyle verilmeli.

IOC Zenginleştirme Sonuçları

Sample-10: access-accsecurity[.]com ve thculturfdes.co[.]uk VirusTotal'da temiz (henüz kataloglanmamış olabilir). Kaynak IP 89.144.44[.]2 VirusTotal'da 0/89 ama "2 detected files communicating with this IP" notu var, geçmişte iki ayrı zararlı dosyanın C2 iletişimi için kullandığı bir adres, paylaşımlı kötü niyetli altyapıya işaret ediyor.

Sample-95: Kaynak IP (143.55.227[.]147, Mailgun) AbuseIPDB'de whitelisted, meşru toplu mail altyapısı. Asıl hedef drop-coin-availablenow.site44[.]com VirusTotal'da 10/89 motor tarafından "Phishing" (Webroot: "Malicious") olarak doğrulanmış, 19 gün önce son analiz edilmiş, hâlâ aktif. Yönlendirici usertest.sciquest[.]com kendisi temiz ama "en az 1 zararlı dosyaya gömülü" notu taşıyor.

Sample-800: Kaynak IP (40.107.223[.]119, Microsoft) AbuseIPDB'de 35 kez raporlanmış ama %0 confidence, paylaşımlı dev altyapı, itibar seyrelmiş. Asıl hedef appbnb.web[.]app VirusTotal'da tamamen temiz (3 yıldır yeniden analiz edilmemiş, dış doğrulama yok). Yönlendirici click.pstmrk[.]it kendisi temiz ama "en az 10 zararlı dosyaya gömülü" notu taşıyor. Bu örnekte karar dış itibar servislerinden değil iç kanıtlardan (DKIM yok, DMARC sadece tahmin, homoglyph hilesi, tekrarlayan dolgu metni) geliyor.

Kullanıcı Bildirim Metinleri

Sample-10:

Merhaba, bildirdiğiniz e-posta gerçek bir Microsoft uyarısı değil, bir ortalama denemesi. Gönderen adresi Microsoft'a ait değil ve e-postadaki hiçbir bağlantı gerçek bir Microsoft sayfasına gitmiyor, hepsi saldırganın kendi mail adresine yönlendiriyor. E-postayı silebilirsiniz. Eğer "Report The User" ya da başka bir bağlantıya tıklayıp saldırganla yazıştıysanız, ona hiçbir kişisel bilgi (parola, doğrulama kodu) vermediğinizden emin olun ve bu yazışmayı da bize iletin.

Sample-95:

Merhaba, bildirdiğiniz e-posta gerçek Trustwallet'tan gelmiyor, bir kripto cüzdanı ortalaması ve hedef sayfası güvenlik firmaları tarafından doğrulanmış bir phishing sayfası. E-postayı silin, "Confirm my wallet" bağlantısına tıklamayın. Eğer zaten tıkladıysanız ve cüzdanınızın kurtarma ifadesini (seed

phrase) ya da özel anahtarınızı herhangi bir sayfaya girdiyseniz, o cüzdanı ele geçirilmiş kabul edin ve içindeki varlıkları hemen yeni, güvenli bir cüzdana taşıyın. Sadece kullanıcı adı/parola girdiyseniz, o hesabın parolasını değiştirin.

Sample-800:

Merhaba, bildirdiğiniz e-posta gerçek bir BNB/Binance airdrop duyurusu değil, bir kripto oltalaması. Gönderen, Microsoft'un altyapısını kötüye kullanmış olsa da içerik sahte. E-postayı silin, bağlantıya tıklamayın. Eğer bağlantıya tıklayıp cüzdanınızı bir siteye bağladıysanız ya da özel anahtar/seed phrase girdiyseniz, cüzdanı ele geçirilmiş sayın ve varlıklarınızı güvenli bir cüzdana taşıyın. Cüzdanınızı sadece bağladıysanız (işlem onaylamadıysanız), bağlantı izinlerini web3 cüzdan uygulamanızdan iptal edin.

Üç Örnek Karşılaştırma

	Sample-10	Sample-95	Sample-800
Kararı asıl belirleyen	SPF/DKIM/DMARC hepsi olumsuz	DMARC uyumsuzluğu (spf/dkim pass, dmarc fail)	Homoglyph + DKIM yok + dolgu metni
SPF	none	pass	pass
DKIM	none	pass	none
DMARC	permerror	fail	bestguesspass
Kullanılan altyapı	Kendi/küçük domain	Mailgun + Gorgias (çalınmış/kötüye kullanılmış)	Microsoft 365 (geçici tenant)
Hedef	mailto: (sosyal mühendislik)	Sahte web sayfası	Sahte web sayfası
Dış doğrulama(VT)	Zayıf, ama IP geçmişi var	Güçlü, hedef doğrulanmış	Zayıf, iç kanıta dayalı

Sample-10'da saldırgan kendi/küçük bir domain kullandığı için hiçbir doğrulama geçmiyor, en kolay tespit edilen durum. Sample-95 ve Sample-800'de saldırganlar meşru, büyük ölçekli mail altyapılarını (Mailgun/Gorgias, Microsoft 365) kötüye kullandığı için SPF geçiyor, hatta bazı DKIM imzaları da geçerli. Aradaki fark DMARC hizalamasında ortaya çıkıyor: Sample-95'te DKIM imzalayan domain ile From domaini uyumuyor (dmarc=fail), Sample-800'de ise From ile Return-Path aynı olduğu için DMARC bile "tahmin" yoluyla geçiyor (bestguesspass). Bu, saldırganın kendi domaini olmasa da geçici bir Microsoft tenant'ı kullanarak neredeyse tam bir hizalama elde ettiğini gösteriyor. Yani doğrulama sonuçları, saldırganın altyapıyı ne kadar "meşrulaştırdığına" bağlı, tehdidin ciddiyetine değil.